

Cyber Threat Intelligence and Machine Learning

Jon C. Haass
Cyber Intelligence and Security
Embry-Riddle Aeronautical University
Prescott, AZ USA
Jon.Haass@erau.edu

Abstract—Cyber Threat Intelligence has been demonstrated to be an effective element of defensive security and cyber protection with examples dating back to the founding of the Financial Sector Information Sharing and Analysis Center (FS ISAC) in 1998. Automated methods are needed today in order to stay current with the magnitude of attacks across the globe. Threat information must be actionable, current and credibly validated if they are to be ingested into computer operated defense systems. False positives degrade the value of the system. This paper outlines some of the progress made in applying artificial intelligence techniques as well as the challenges associated with utilizing machine learning to refine the flow of threat intelligence. A variety of methods have been developed to create learning models that can be integrated with firewalls, rules and heuristics. In addition more work is needed to effectively support the limited number of expert human hours available to evaluate the prioritized threat landscape flagged as malicious in a (Security Operations Center) SOC environment.

Keywords— *Threat Intelligence, Machine Learning, ML, Cyber Threats, Knowledge Graphs, Artificial Intelligence, AI, Cyber Protection, Malware Analysis*

I. INTRODUCTION

Cyber threats have a variety and volume combined with a velocity that outstrips the ability of most organizations to defend and mitigate in the event of an attempted or successful breach. This Big Data aspect of threat intelligence has attracted the investigation by academic, commercial and government researchers. The current workforce shortfall in the US alone is over 600,000, a number only achievable if the training model changes and the utilization of manpower shifts as it has done in other sectors with automation and innovation. Machine learning based artificial intelligence holds promise to disrupt the SOC, as it has already done for foreign currency exchange and arbitrage. Challenges are many in the deploying of high performance machine learning systems; development of models, creating or discovering appropriate optimization functions and metrics, extracting appropriate features from potential attack vectors and improving the learning systems in live environments.

A subset problem is to automatically detect and quarantine Windows based malware, an objective of anti-virus systems for over 20 years. The large volume of client data provides an excellent set of sample information (some of it partially labelled) however most of it is proprietary to the different vendors competing in the space [1]. Another related problem is the discovery of malware in dark web or deep net forums. Here, a

semi supervised approach was demonstrated to have success finding zero day threats being sold using Bitcoin as the payment [2]. A goal of the research is to develop systems that can assist in protecting the confidentiality, integrity and availability (CIA) of large and distributed organizations at a reduced cost, with improved time between incident and discovery. Only upon identification can remediation and recovery steps be deployed.

II. CYBER THREAT INTELLIGENCE

MITRE and others have developed a taxonomy for describing cyber threats based upon heuristics, signatures, techniques and practices. Researchers have worked on tasks associated with creating vector descriptions that can be utilized by current learning algorithms [3]. Un supervised or semi supervised reduce the problem of labelling which is expert time intensive. It may prove necessary to provide some labels as part of the initial setup of the metric functionals required by the learning systems. Additionally vendors ranging from next generation firewall to end point protection are gathering data from their global customer base into cloud based data stores with API agreements with partners promising a depth of data with time stamp, att@ck taxonomy and other signatures [4].

A standardized approach has been developed Structured Threat Information Expression (STIX) that has been used to develop vectors that can be compared or presented in a graph like structure [5]. Machine learning algorithms can traverse the graph and make predictions on the likelihood of malicious capabilities based on likelihood statistics comparing to other attacks seen in the wild [6][7]. The generalized problem, though easy to express, may have approaches to solutions that cannot be readily understood and/or easily evaluated particularly with some neural net methods. The new area of provable or explainable AI may actually limit the value of some novel activity that unfettered AI may exhibit [8].

III. MACHINE LEARNING APPROACH

Machine Learning has a relatively long and checkered history tackling a variety of problems. The core challenge is describing an appropriate non-trivial functional to be maximized or minimized in order to define the membership in the category of cybersecurity threat. Ideally an algorithm would further cluster candidates in a priority rank from severe to mild. An adversarial learning model would additionally evolve to be able to discern zero day threats based on the data.

Partially supported by DoD CySP grants H98230-20-1-0393 and H98230-21-1-0239.

In recent work presented, the data gathered from a threat sample included the standard signatures such as size, hash, connections, network access but also fine structure details derived from the assembly code in the form of strings as well as 1, 2 and 3 instruction “vectors” of op codes. The thesis being that code is re-used even if an adversary attempts to obfuscate through randomizing compilation or no-op code injection. In admittedly limited testing the method was able to classify malicious software as being a member of the same family [3].

Other machine learning algorithms have been developed to traverse a graph constructed from open source tools, creating relations, attributes and identity. Elements of the graph can be compared to determine if there is a new relationship (derived from, parent of, shared elements etc.) in order to evaluate potential threat and possible mitigation. These methods benefit from the well-studied machinery associated with graph similarity and decomposition [7].

One of the primary difficulties has been the evolutionary nature of the adversarial threat and tendency to have “adversarial drift” impact the efficacy of the learning function. Old information can dominate the weighting functions resulting in increased false positives and false negatives over time. With adversaries using test suites comprised of tools widely available in the open source, such as the web based Virus Total, modifications to attacks can be tuned to largely evade detection. Heuristic analysis requires time to observe malicious behavior which may be delayed with the use of timers giving the impression of a benign behavior. End point detection may be too slow to discover unusual behavior until harm such as encryption by ransomware is already underway and difficult to stop or interrupt [9]. Re-training of the detection system may be able to improve the results by maximizing the ROC function when it drops below some threshold set in an outer layer of multi stage system.

IV. STATE OF THE ART IMPLEMENTATIONS

Researchers compete with proprietary techniques developed by commercial databases from the clients of a specific vendor. For example the FireEye Threat Map depicts a subset of attacks happening across the customer network being protected by the company and its partners. Elements of the incident map include IP address of attacker and target, sector, classification of attack and other pertinent data. Gathering this disparate data types results in an unstructured dataset with holes where information is missing from some of the entries. This is typical of the real world data that must be handled by machine or human researchers [10].

TABLE I. KEYWORDS USED IN CLASS SORTING

Sample Relevant Keywords
adware, antivirus (kaspersky, avast, avira, ...), backdoor, botnet, breach, chware, crack, crimeware, crypter, cve, cyberweapon, ddos, down-loader, dropper, exploit, firewall, hijack, infect, keylogger, logic bomb, malware, monetizer, password, payload, RAT, ransomware, reverse shell, riskware, rootkit, scanner, security, shell code, spam, spoof, spyware, stealware, trojan, virus, vulnerability, worm, zero-day, zeuss

Another approach is to utilize forums as sources for verification or validation of existing malware being offered on the dark net. Keyword sets were used in a comparison of approaches to augment supervised and labeled datasets [11]. Sample keywords are shown in Table I above and were used to be able to discover malware in the wild over a period of weeks by creating two classes: relevant and irrelevant.

The number of vertices of the graph created using an approach such as this is typically on the order of thousands with subgraphs collapsing due to incomplete entries or the non-critical nature of some vector entries in the node map. Over time a series flow is possible as measurements detect similar features (attacks / malware / IoC – Indicators of Compromise) creating stronger connections in the time series. Approaches include clustering, neural net and SVM (Support Vector Machine) with roughly similar capability in finding true positives. The number of false positives separated the approaches and are the most promising for at scale.

For instance large organizations such as Nippon Telegraph and Telephone Corporation (NTT) are creating commercial applications using a variety of techniques to offer Cyber Threat Sensor AI (CTSAI). It ingests data from internal and external data feeds including ISAC information for the specific sector for a given client profile. Cross sector data is included with a different weight function. This black box approach works well for smaller organizations unable to support their own SOC infrastructure. The variety of data sources and size of the logs generated continues to grow as network traffic, connection oriented logging and end point monitoring becomes standard practice. Deep packet inspection now allows the operator to look inside https streams prior to allowing binary data to be stored on an end user device. Additional layers of encryption, disguising as images (steganography) cannot be avoided in this scheme but a rule can be included to dis allow such payloads, forcing them to be unopened until quarantined, unpacked and authorized.

This combined approach will evolve to generate a higher level of protection with vanishingly small false positives or passed through threats. Feature extraction and graph cleaning methods remain an area of continued research. Recent work in different domains provide promise but also suggest that a universal method may not be possible though the architecture and tool flow may be reusable. Data sources used in the analysis are listed in Table II.

TABLE II. DISPARATE DATA SOURCES

Sources Used in Survey
Company network traffic, Security Information and Event Management (SIEM) or Log data, End Point or Client data, ISAC and Industry sources, Vulnerability databases, Open Source forums and data markets, on-line repositories.

The method being explored treats the dis-assembled code features such as strings, function calls, assembly primitives as elements that can be compared to known labelled malware or attacks. The weighting function reflects the likelihood of being found in the entire corpus of benign and malicious code. This

method emphasizes the unique “signatures”, inversely weighted to their rare appearance in analysis. This can provide an automated method of removing some vertices in the presentation graph. Those elements with large weights would be dominant in discriminating the likelihood of reused code coming from an already labelled malicious source. Re-used code segments produce sub-graphs that can be extracted and replaced with a sort of weighted super node or vertex in the graph representation. A threat can be measured as close to a known malicious family or identified as a novel implementation if sufficiently far from any known variant family. This could trigger an alert to investigate in a dynamic analysis environment, a process that is more expensive in both time and human interaction to determine as a true positive threat, malware or possible attack campaign. In (1) below, a document D represents the file sample with n elements q indexed by k . The function describes the $k1$ weighting based on the sampling of primitives.

$$F(D(q)) = \sum_{k=0}^n F(q_k) \cdot ((k1+1) \cdot f(q, D)) / (f(q_k, D) + (k1 \cdot (1-b + b \cdot |D|)))$$

(1)

Comparison of the elements within the weighted equation and result in sets of signatures. The individual members can be queried at a later time by an analyst alone or in the context of a static analysis engine such as IDA Pro or Ghidra. Dynamic analysis would be used to investigate in a running environment once the flagged positive malware document is investigated for targeting and deployment [3].

V. CHALLENGES AND OPPORTUNITY

The algorithmic approach has been tested with a limited set of training and malware samples at this point. Working with a larger incoming stream of potential samples will allow more experimentation and refinement of the approach [12]. Questions to be addressed include the impact of anti-analysis techniques such as obfuscation and encodings. Will the method degrade as the volume of analyzed software increases resulting in reduced effectiveness? Will periodic retraining be required and how will that be managed and measured? With 316,000 new threats being released onto the network daily in 2022, an automated approach with high degree of accuracy is required to prevent the probability of significant financial loss occurring compared to the investment in new technology or large workforce.

New techniques are being developed and tested using a multi stage approach that promises improved adaptation to the changing environment with its associated adversarial drift. Allowing new data to be introduced to the operational system shows promise but challenges the structure to avoid over tuning to the point of missing actual threats.

A time series signature approach can identify if a specific document or executable has significant inheritance from a previously studied sample. At some point the distance from a cluster may require a pruning or exclusion thereby initiating a new family based on behavior, structure or other unique attribute that needs to be incorporated into the learning model. Samples that fall outside require additional examination and could result in an update to the overall system. If this can be managed much

as operating system patches or malware signature databases, then the approach can be incorporated into a production level tool chain.

This approach is being studied in prototype form using live fire cyber warfare range as a testing ground. It has actual configurations, users, operational systems such as finance, human resources and development in a highly monitored and surveilled environment. It provides a system of systems approach familiar in large scale systems such as aerospace, manufacturing or international finance.

Incoming data is filtered and run through detectors and then provide the input to a learning stage that seeks to flag anomalies for additional study and action. The system can have larger latency than desirable for some time critical applications however the critical path studies are identifying areas for improvement and possible parallel implementation. A simple diagram in Figure 1 below provides an indication of part of the workflow model [13].

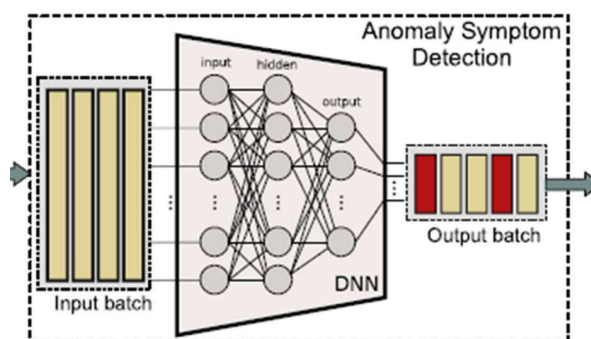


Fig. 1. Example of deep neural net (DNN) stage of detection workflow.

Artificial intelligence methods are being improved in many application areas. Cross functional teams with experience in healthcare, high performance computing, genetics, cyber security mathematics, and finance bring their own knowledge together to help create more robust cyber protection solutions using a variety of artificial intelligence, computer science and graph theoretic methods.

ACKNOWLEDGMENT

Thanks to discussions with Joe Barr that helped in the development of ideas for the paper and in jointly organizing the first summer workshop on Artificial Intelligence for Cyber Protection (AI4CP) held in Prescott Arizona August 19-21. Ideas discussed at the workshop helped inform many of the concepts presented. Also appreciative of Peter Shaw for his efforts in planning and implementing the TransAI conference held in Laguna Hills, September 2022 that was a sponsor for the preceding workshop.

REFERENCES

- [1] CrowdStrike™ Launches Intelligence Exchange Program (CSIX), “Integrate and Innovate,” 2014, Black Hat 2014, Las Vegas NV. 55.

- [2] E. Nunes et al., "Darknet and deepnet mining for proactive cybersecurity threat intelligence," 2016 IEEE Conference on Intelligence and Security Informatics (ISI), 2016, pp. 7-12, doi: 10.1109/ISI.2016.7745435.
- [3] C. Molloy, P. Charland, S. H. H. Ding and B. C. M. Fung, "JARVIS: Phenotype Clone Search for Rapid Zero-Day Malware Triage and Functional Decomposition for Cyber Threat Intelligence," 2022 14th International Conference on Cyber Conflict: Keep Moving! (CyCon), 2022, pp. 385-403, doi: 10.23919/CyCon55549.2022.9811078.
- [4] K. Kurniawan, A. Ekelhart, and E. Kiesling. "An ATT&CK-KG for Linking Cybersecurity Attacks to Adversary Tactics and Techniques". 2021 Conference ISWC 2021.
- [5] K. Liu et al., "A review of knowledge graph application scenarios in cyber security." ArXiv abs/2204.04769, 2022: n. pg. 33.
- [6] Y. Shaikat K, Luo S, Varadharajan V, Hameed IA, Xu M. "A survey on machine learning techniques for cyber security in the last decade". IEEE Access. Dec 2;8:222310-54, 2020.
- [7] A. Hogan et al. "Knowledge graphs[J]. Synthesis Lectures on Data, Semantics, and Knowledge," 2021, 12(2): 1-257.
- [8] B. Schneier "The Coming AI Hackers", Belfer Center for Science and International Affairs, paper, April 2021.
- [9] F. Liang, W. G. Hatcher, W. Liao, W. Gao and W. Yu, "Machine Learning for Security and the Internet of Things: The Good, the Bad, and the Ugly," in IEEE Access, vol. 7, pp. 158126-158147, 2019, doi: 10.1109/ACCESS.2019.2948912.
- [10] T. Wagner, K. Mahbub, E. Palomar, and A. Abdallah, "Cyber threat intelligence sharing: Survey and research directions", Computers & Security, ISSN 0167-4048, Volume 87, 2019.
- [11] I. Deliu, C. Leichter and K. Franke, "Extracting cyber threat intelligence from hacker forums: Support vector machines versus convolutional neural networks," 2017 IEEE International Conference on Big Data (Big Data), 2017, pp. 3648-3656, doi: 10.1109/BigData.2017.8258359.
- [12] N. Kaloudi, L. Jingyue, "The AI-based cyber threat landscape", ACM Computing Surveys, Volume 53, Issue 1, January 2021, Article No. 20 pp 1-34 <https://doi.org/10.1145/3372823> 2021.
- [13] L. Fernández Maimó, Á. L. Perales Gómez, F. J. García Clemente, M. Gil Pérez and G. Martínez Pérez, "A Self-Adaptive Deep Learning-Based System for Anomaly Detection in 5G Networks," in IEEE Access, vol. 6, pp. 7700-7712, 2018, doi: 10.1109/ACCESS.2018.2803446.